VulnScan Vulnerability Scan Report

Scan ID	#8	Scan Name	Test Shop (demo)
Target URL	http://127.0.0.1:5001/	Scan Profile	OWASP Top 10 Full Scan
Status	Completed	Started By	developer@vulnscan.local
Started At	2026-09-10T04:22:36.283000	Finished At	2026-09-10T04:22:57.303000

Summary

Severity	Count
None	0
Low	0
Medium	11
High	0
Critical	2
Total	13

Findings (13)

#	Vulnerability	Severity	Risk	Status	Location
1	Missing HTTP Security Headers	Medium	5.4	Open	http://127.0.0.1:5001/
2	Cross-Site Scripting (XSS)	Medium	6.1	Open	http://127.0.0.1:5001/search?q=laptop
3	Missing HTTP Security Headers	Medium	5.4	Open	http://127.0.0.1:5001/search?q=laptop
4	Missing HTTP Security Headers	Medium	5.4	Open	http://127.0.0.1:5001/safe_search?q=laptop
5	SQL Injection	Critical	9.8	Open	http://127.0.0.1:5001/product?id=1
6	Missing HTTP Security Headers	Medium	5.4	Open	http://127.0.0.1:5001/product?id=1
7	SQL Injection	Critical	9.8	Open	http://127.0.0.1:5001/product?id=2
8	Missing HTTP Security Headers	Medium	5.4	Open	http://127.0.0.1:5001/product?id=2
9	SQL Injection	Medium	5.9	Open	http://127.0.0.1:5001/blind?id=1
10	Cross-Site Scripting (XSS)	Medium	6.1	Open	http://127.0.0.1:5001/blind?id=1
11	Missing HTTP Security Headers	Medium	5.4	Open	http://127.0.0.1:5001/blind?id=1
12	Missing HTTP Security Headers	Medium	5.4	Open	http://127.0.0.1:5001/boolean_safe?id=1
13	Missing HTTP Security Headers	Medium	5.4	Open	http://127.0.0.1:5001/about

1. Missing HTTP Security Headers (Medium)

Location: http://127.0.0.1:5001/
Parameter: HTTP Response Headers
Payload: `Content-Security-Policy,X-Frame-Options,X-Content-Type-Options,Referrer-Policy,Permissions-Policy`
Status: Open
Evidence class: Confirmed (CVSS 5.4, confidence 95%)
Description: Security misconfiguration occurs when a web server or application is deployed without recommended HTTP security headers such as Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy and Permissions-Policy.
Impact: Increased exposure to clickjacking, MIME sniffing, referrer leakage and weakened defence-in-depth against XSS and other client-side attacks.
Remediation: Set the missing security headers with secure values; enforce HSTS on HTTPS pages; verify configuration after every deployment.
Evidence: CONFIRMED: the HTTP response for this page does not include all recommended security headers with secure values. Missing headers: - Content-Security-Policy: Content Security Policy (CSP) is missing, increasing the risk of cross-site scripting and content injection. - X-Frame-Options: X-Frame-Options is missing or not set to DENY/SAMEORIGIN, allowing the page to be framed by other sites (clickjacking). - X-Content-Type-Options: X-Content-Type-Options is missing or not set to 'nosniff', allowing MIME-type sniffing. - Referrer-Policy: Referrer-Policy is missing or set to an unsafe value; the Referer header may leak URL data. - Permissions-Policy: Permissions-Policy is missing, so browser features are not restricted. Security misconfiguration: one or more recommended HTTP security headers are missing or improperly configured. Suggested fixes: - Content-Security-Policy: Set a Content-Security-Policy header (e.g. default-src 'self'). - X-Frame-Options: Set X-Frame-Options: DENY (or SAMEORIGIN), or use CSP frame-ancestors. - X-Content-Type-Options: Set X-Content-Type-Options: nosniff. - Referrer-Policy: Set Referrer-Policy: strict-origin-when-cross-origin (or no-referrer). - Permissions-Policy: Set a Permissions-Policy header that disables unused features.

2. Cross-Site Scripting (XSS) (Medium)

Location: http://127.0.0.1:5001/search?q=laptop
Parameter: q
Payload: `vulnscan_xss_7f3a9c`
Status: Open
Evidence class: Confirmed (CVSS 6.1, confidence 92%)
Description: Cross-Site Scripting (XSS) allows an attacker to inject client-side scripts into web pages viewed by other users. Reflected XSS occurs when input is echoed back without output encoding.
Impact: Session hijacking, account takeover, credential theft, defacement and the execution of arbitrary actions in the context of the victim.
Remediation: Apply context-aware output encoding, use a Content Security Policy (CSP), set the HttpOnly and Secure flags on cookies, and sanitise untrusted HTML input.
Evidence: CONFIRMED: the raw XSS payload 'vulnscan_xss_7f3a9c' was reflected byte-for-byte (unencoded) in the HTML response for parameter 'q'. Reflected cross-site scripting detected: attacker-controlled input is echoed without output encoding.

3. Missing HTTP Security Headers (Medium)

Location: http://127.0.0.1:5001/search?q=laptop
Parameter: HTTP Response Headers
Payload: `Content-Security-Policy,X-Frame-Options,X-Content-Type-Options,Referrer-Policy,Permissions-Policy`
Status: Open
Evidence class: Confirmed (CVSS 5.4, confidence 95%)
Description: Security misconfiguration occurs when a web server or application is deployed without recommended HTTP security headers such as Content-Security-Policy, X-Frame-Options,

X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy and Permissions-Policy.
Impact: Increased exposure to clickjacking, MIME sniffing, referrer leakage and weakened defence-in-depth against XSS and other client-side attacks.
Remediation: Set the missing security headers with secure values; enforce HSTS on HTTPS pages; verify configuration after every deployment.
Evidence: CONFIRMED: the HTTP response for this page does not include all recommended security headers with secure values. Missing headers: - Content-Security-Policy: Content Security Policy (CSP) is missing, increasing the risk of cross-site scripting and content injection. - X-Frame-Options: X-Frame-Options is missing or not set to DENY/SAMEORIGIN, allowing the page to be framed by other sites (clickjacking). - X-Content-Type-Options: X-Content-Type-Options is missing or not set to 'nosniff', allowing MIME-type sniffing. - Referrer-Policy: Referrer-Policy is missing or set to an unsafe value; the Referer header may leak URL data. - Permissions-Policy: Permissions-Policy is missing, so browser features are not restricted. Security misconfiguration: one or more recommended HTTP security headers are missing or improperly configured. Suggested fixes: - Content-Security-Policy: Set a Content-Security-Policy header (e.g. default-src 'self'). - X-Frame-Options: Set X-Frame-Options: DENY (or SAMEORIGIN), or use CSP frame-ancestors. - X-Content-Type-Options: Set X-Content-Type-Options: nosniff. - Referrer-Policy: Set Referrer-Policy: strict-origin-when-cross-origin (or no-referrer). - Permissions-Policy: Set a Permissions-Policy header that disables unused features.

4. Missing HTTP Security Headers (Medium)

Location: http://127.0.0.1:5001/safe_search?q=laptop
Parameter: HTTP Response Headers
Payload: `Content-Security-Policy,X-Frame-Options,X-Content-Type-Options,Referrer-Policy,Permissions-Policy`
Status: Open
Evidence class: Confirmed (CVSS 5.4, confidence 95%)
Description: Security misconfiguration occurs when a web server or application is deployed without recommended HTTP security headers such as Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy and Permissions-Policy.
Impact: Increased exposure to clickjacking, MIME sniffing, referrer leakage and weakened defence-in-depth against XSS and other client-side attacks.
Remediation: Set the missing security headers with secure values; enforce HSTS on HTTPS pages; verify configuration after every deployment.
Evidence: CONFIRMED: the HTTP response for this page does not include all recommended security headers with secure values. Missing headers: - Content-Security-Policy: Content Security Policy (CSP) is missing, increasing the risk of cross-site scripting and content injection. - X-Frame-Options: X-Frame-Options is missing or not set to DENY/SAMEORIGIN, allowing the page to be framed by other sites (clickjacking). - X-Content-Type-Options: X-Content-Type-Options is missing or not set to 'nosniff', allowing MIME-type sniffing. - Referrer-Policy: Referrer-Policy is missing or set to an unsafe value; the Referer header may leak URL data. - Permissions-Policy: Permissions-Policy is missing, so browser features are not restricted. Security misconfiguration: one or more recommended HTTP security headers are missing or improperly configured. Suggested fixes: - Content-Security-Policy: Set a Content-Security-Policy header (e.g. default-src 'self'). - X-Frame-Options: Set X-Frame-Options: DENY (or SAMEORIGIN), or use CSP frame-ancestors. - X-Content-Type-Options: Set X-Content-Type-Options: nosniff. - Referrer-Policy: Set Referrer-Policy: strict-origin-when-cross-origin (or no-referrer). - Permissions-Policy: Set a Permissions-Policy header that disables unused features.

5. SQL Injection (Critical)

Location: http://127.0.0.1:5001/product?id=1
Parameter: id
Payload: `'`
Status: Open
Evidence class: Confirmed (CVSS 9.8, confidence 92%)

Description: SQL Injection (SQLi) occurs when untrusted user input is embedded directly into SQL queries without parameterisation. An attacker can manipulate queries to read, modify or delete database records, bypass authentication or execute administrative functions.
Impact: Unauthorised access to sensitive data, data loss or corruption, authentication bypass, and in severe cases full compromise of the database server.
Remediation: Use parameterised queries / prepared statements and stored procedures exclusively. Apply strict input validation and least-privilege database accounts. Never concatenate user input into SQL.
Evidence: CONFIRMED: database error signature 'unclosed quotation mark' appeared after injecting the payload "'" into parameter 'id'; the signature was absent from the baseline response. Error-based SQL injection. The application returned a database error caused by the injected SQL metacharacter, indicating that user input reaches a SQL query without parameterisation.

6. Missing HTTP Security Headers (Medium)

Location: http://127.0.0.1:5001/product?id=1
Parameter: HTTP Response Headers
Payload: `Content-Security-Policy,X-Frame-Options,X-Content-Type-Options,Referrer-Policy,Permissions-Policy`
Status: Open
Evidence class: Confirmed (CVSS 5.4, confidence 95%)
Description: Security misconfiguration occurs when a web server or application is deployed without recommended HTTP security headers such as Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy and Permissions-Policy.
Impact: Increased exposure to clickjacking, MIME sniffing, referrer leakage and weakened defence-in-depth against XSS and other client-side attacks.
Remediation: Set the missing security headers with secure values; enforce HSTS on HTTPS pages; verify configuration after every deployment.
Evidence: CONFIRMED: the HTTP response for this page does not include all recommended security headers with secure values. Missing headers: - Content-Security-Policy: Content Security Policy (CSP) is missing, increasing the risk of cross-site scripting and content injection. - X-Frame-Options: X-Frame-Options is missing or not set to DENY/SAMEORIGIN, allowing the page to be framed by other sites (clickjacking). - X-Content-Type-Options: X-Content-Type-Options is missing or not set to 'nosniff', allowing MIME-type sniffing. - Referrer-Policy: Referrer-Policy is missing or set to an unsafe value; the Referer header may leak URL data. - Permissions-Policy: Permissions-Policy is missing, so browser features are not restricted. Security misconfiguration: one or more recommended HTTP security headers are missing or improperly configured. Suggested fixes: - Content-Security-Policy: Set a Content-Security-Policy header (e.g. default-src 'self'). - X-Frame-Options: Set X-Frame-Options: DENY (or SAMEORIGIN), or use CSP frame-ancestors. - X-Content-Type-Options: Set X-Content-Type-Options: nosniff. - Referrer-Policy: Set Referrer-Policy: strict-origin-when-cross-origin (or no-referrer). - Permissions-Policy: Set a Permissions-Policy header that disables unused features.

7. SQL Injection (Critical)

Location: http://127.0.0.1:5001/product?id=2
Parameter: id
Payload: `'`
Status: Open
Evidence class: Confirmed (CVSS 9.8, confidence 92%)
Description: SQL Injection (SQLi) occurs when untrusted user input is embedded directly into SQL queries without parameterisation. An attacker can manipulate queries to read, modify or delete database records, bypass authentication or execute administrative functions.
Impact: Unauthorised access to sensitive data, data loss or corruption, authentication bypass, and in severe cases full compromise of the database server.
Remediation: Use parameterised queries / prepared statements and stored procedures exclusively. Apply strict input validation and least-privilege database accounts. Never concatenate user input into SQL.

Evidence: CONFIRMED: database error signature 'unclosed quotation mark' appeared after injecting the payload "'" into parameter 'id'; the signature was absent from the baseline response. Error-based SQL injection. The application returned a database error caused by the injected SQL metacharacter, indicating that user input reaches a SQL query without parameterisation.

8. Missing HTTP Security Headers (Medium)

Location: http://127.0.0.1:5001/product?id=2
Parameter: HTTP Response Headers
Payload: `Content-Security-Policy,X-Frame-Options,X-Content-Type-Options,Referrer-Policy,Permissions-Policy`
Status: Open
Evidence class: Confirmed (CVSS 5.4, confidence 95%)
Description: Security misconfiguration occurs when a web server or application is deployed without recommended HTTP security headers such as Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy and Permissions-Policy.
Impact: Increased exposure to clickjacking, MIME sniffing, referrer leakage and weakened defence-in-depth against XSS and other client-side attacks.
Remediation: Set the missing security headers with secure values; enforce HSTS on HTTPS pages; verify configuration after every deployment.
Evidence: CONFIRMED: the HTTP response for this page does not include all recommended security headers with secure values. Missing headers: - Content-Security-Policy: Content Security Policy (CSP) is missing, increasing the risk of cross-site scripting and content injection. - X-Frame-Options: X-Frame-Options is missing or not set to DENY/SAMEORIGIN, allowing the page to be framed by other sites (clickjacking). - X-Content-Type-Options: X-Content-Type-Options is missing or not set to 'nosniff', allowing MIME-type sniffing. - Referrer-Policy: Referrer-Policy is missing or set to an unsafe value; the Referer header may leak URL data. - Permissions-Policy: Permissions-Policy is missing, so browser features are not restricted. Security misconfiguration: one or more recommended HTTP security headers are missing or improperly configured. Suggested fixes: - Content-Security-Policy: Set a Content-Security-Policy header (e.g. default-src 'self'). - X-Frame-Options: Set X-Frame-Options: DENY (or SAMEORIGIN), or use CSP frame-ancestors. - X-Content-Type-Options: Set X-Content-Type-Options: nosniff. - Referrer-Policy: Set Referrer-Policy: strict-origin-when-cross-origin (or no-referrer). - Permissions-Policy: Set a Permissions-Policy header that disables unused features.

9. SQL Injection (Medium)

Location: http://127.0.0.1:5001/blind?id=1
Parameter: id
Payload: `1 AND '1'='1`
Status: Open
Evidence class: Suspected (CVSS 5.9, confidence 60%)
Description: SQL Injection (SQLi) occurs when untrusted user input is embedded directly into SQL queries without parameterisation. An attacker can manipulate queries to read, modify or delete database records, bypass authentication or execute administrative functions.
Impact: Unauthorised access to sensitive data, data loss or corruption, authentication bypass, and in severe cases full compromise of the database server.
Remediation: Use parameterised queries / prepared statements and stored procedures exclusively. Apply strict input validation and least-privilege database accounts. Never concatenate user input into SQL.
Evidence: SUSPECTED (blind/boolean): a logically-true SQL condition resembled the baseline response (similarity 0.78) more closely than the logically-false condition did (0.29); the two responses also differed from each other (similarity 0.38) and were stable across repeats. Reflected payload text was masked before comparison. Manual verification is recommended. Boolean-based (blind) SQL injection is suspected. No database error was observed, so this finding is reported with lower confidence; confirmation requires manual testing.

10. Cross-Site Scripting (XSS) (Medium)

Location: http://127.0.0.1:5001/blind?id=1
Parameter: id
Payload: `vulnscan_xss_7f3a9c`
Status: Open
Evidence class: Confirmed (CVSS 6.1, confidence 92%)
Description: Cross-Site Scripting (XSS) allows an attacker to inject client-side scripts into web pages viewed by other users. Reflected XSS occurs when input is echoed back without output encoding.
Impact: Session hijacking, account takeover, credential theft, defacement and the execution of arbitrary actions in the context of the victim.
Remediation: Apply context-aware output encoding, use a Content Security Policy (CSP), set the HttpOnly and Secure flags on cookies, and sanitise untrusted HTML input.
Evidence: CONFIRMED: the raw XSS payload 'vulnscan_xss_7f3a9c' was reflected byte-for-byte (unencoded) in the HTML response for parameter 'id'. Reflected cross-site scripting detected: attacker-controlled input is echoed without output encoding.

11. Missing HTTP Security Headers (Medium)

Location: http://127.0.0.1:5001/blind?id=1
Parameter: HTTP Response Headers
Payload: `Content-Security-Policy,X-Frame-Options,X-Content-Type-Options,Referrer-Policy,Permissions-Policy`
Status: Open
Evidence class: Confirmed (CVSS 5.4, confidence 95%)
Description: Security misconfiguration occurs when a web server or application is deployed without recommended HTTP security headers such as Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy and Permissions-Policy.
Impact: Increased exposure to clickjacking, MIME sniffing, referrer leakage and weakened defence-in-depth against XSS and other client-side attacks.
Remediation: Set the missing security headers with secure values; enforce HSTS on HTTPS pages; verify configuration after every deployment.
Evidence: CONFIRMED: the HTTP response for this page does not include all recommended security headers with secure values. Missing headers: - Content-Security-Policy: Content Security Policy (CSP) is missing, increasing the risk of cross-site scripting and content injection. - X-Frame-Options: X-Frame-Options is missing or not set to DENY/SAMEORIGIN, allowing the page to be framed by other sites (clickjacking). - X-Content-Type-Options: X-Content-Type-Options is missing or not set to 'nosniff', allowing MIME-type sniffing. - Referrer-Policy: Referrer-Policy is missing or set to an unsafe value; the Referer header may leak URL data. - Permissions-Policy: Permissions-Policy is missing, so browser features are not restricted. Security misconfiguration: one or more recommended HTTP security headers are missing or improperly configured. Suggested fixes: - Content-Security-Policy: Set a Content-Security-Policy header (e.g. default-src 'self'). - X-Frame-Options: Set X-Frame-Options: DENY (or SAMEORIGIN), or use CSP frame-ancestors. - X-Content-Type-Options: Set X-Content-Type-Options: nosniff. - Referrer-Policy: Set Referrer-Policy: strict-origin-when-cross-origin (or no-referrer). - Permissions-Policy: Set a Permissions-Policy header that disables unused features.

12. Missing HTTP Security Headers (Medium)

Location: http://127.0.0.1:5001/boolean_safe?id=1
Parameter: HTTP Response Headers
Payload: `Content-Security-Policy,X-Frame-Options,X-Content-Type-Options,Referrer-Policy,Permissions-Policy`
Status: Open
Evidence class: Confirmed (CVSS 5.4, confidence 95%)
Description: Security misconfiguration occurs when a web server or application is deployed without recommended HTTP security headers such as Content-Security-Policy, X-Frame-Options,

X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy and Permissions-Policy.
Impact: Increased exposure to clickjacking, MIME sniffing, referrer leakage and weakened defence-in-depth against XSS and other client-side attacks.
Remediation: Set the missing security headers with secure values; enforce HSTS on HTTPS pages; verify configuration after every deployment.
Evidence: CONFIRMED: the HTTP response for this page does not include all recommended security headers with secure values. Missing headers: - Content-Security-Policy: Content Security Policy (CSP) is missing, increasing the risk of cross-site scripting and content injection. - X-Frame-Options: X-Frame-Options is missing or not set to DENY/SAMEORIGIN, allowing the page to be framed by other sites (clickjacking). - X-Content-Type-Options: X-Content-Type-Options is missing or not set to 'nosniff', allowing MIME-type sniffing. - Referrer-Policy: Referrer-Policy is missing or set to an unsafe value; the Referer header may leak URL data. - Permissions-Policy: Permissions-Policy is missing, so browser features are not restricted. Security misconfiguration: one or more recommended HTTP security headers are missing or improperly configured. Suggested fixes: - Content-Security-Policy: Set a Content-Security-Policy header (e.g. default-src 'self'). - X-Frame-Options: Set X-Frame-Options: DENY (or SAMEORIGIN), or use CSP frame-ancestors. - X-Content-Type-Options: Set X-Content-Type-Options: nosniff. - Referrer-Policy: Set Referrer-Policy: strict-origin-when-cross-origin (or no-referrer). - Permissions-Policy: Set a Permissions-Policy header that disables unused features.

13. Missing HTTP Security Headers (Medium)

Location: http://127.0.0.1:5001/about
Parameter: HTTP Response Headers
Payload: `Content-Security-Policy,X-Frame-Options,X-Content-Type-Options,Referrer-Policy,Permissions-Policy`
Status: Open
Evidence class: Confirmed (CVSS 5.4, confidence 95%)
Description: Security misconfiguration occurs when a web server or application is deployed without recommended HTTP security headers such as Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy and Permissions-Policy.
Impact: Increased exposure to clickjacking, MIME sniffing, referrer leakage and weakened defence-in-depth against XSS and other client-side attacks.
Remediation: Set the missing security headers with secure values; enforce HSTS on HTTPS pages; verify configuration after every deployment.
Evidence: CONFIRMED: the HTTP response for this page does not include all recommended security headers with secure values. Missing headers: - Content-Security-Policy: Content Security Policy (CSP) is missing, increasing the risk of cross-site scripting and content injection. - X-Frame-Options: X-Frame-Options is missing or not set to DENY/SAMEORIGIN, allowing the page to be framed by other sites (clickjacking). - X-Content-Type-Options: X-Content-Type-Options is missing or not set to 'nosniff', allowing MIME-type sniffing. - Referrer-Policy: Referrer-Policy is missing or set to an unsafe value; the Referer header may leak URL data. - Permissions-Policy: Permissions-Policy is missing, so browser features are not restricted. Security misconfiguration: one or more recommended HTTP security headers are missing or improperly configured. Suggested fixes: - Content-Security-Policy: Set a Content-Security-Policy header (e.g. default-src 'self'). - X-Frame-Options: Set X-Frame-Options: DENY (or SAMEORIGIN), or use CSP frame-ancestors. - X-Content-Type-Options: Set X-Content-Type-Options: nosniff. - Referrer-Policy: Set Referrer-Policy: strict-origin-when-cross-origin (or no-referrer). - Permissions-Policy: Set a Permissions-Policy header that disables unused features.